

CO2 ASSESSMENT TOOL 2

REVERSE ENGINEERING TASK

Name: SHAIK ASHA

Reg.no: 192473025

Course: ITA1416 – ETHICAL HACKING

Task 1: A cybersecurity team discovers a suspicious executable named FootPrintX.exe on a penetration tester's workstation. The application appears to collect information about target organizations, including domain names, IP addresses, and network details. The source code is unavailable, and the analyst must reverse engineer the binary to understand its functionality. Your task is to identify how the tool performs footprinting activities.

Questions:

1. Which functions or modules are responsible for gathering target information?

The executable FootPrintX.exe likely contains modules responsible for performing reconnaissance and information gathering. These modules may include functions for WHOIS lookups, DNS queries, IP address resolution, network scanning, and HTTP requests. The program may also use Windows networking APIs and socket libraries to communicate with external servers. During reverse engineering, these functions can be identified by analyzing imported libraries, API calls, and network-related routines.

2. What footprinting techniques are implemented in the executable?

The executable appears to implement several footprinting techniques, including:

- WHOIS lookup to obtain domain registration information.
- DNS enumeration to identify DNS records and subdomains.
- IP address resolution to determine the target's network location.
- Reverse DNS lookup to map IP addresses to hostnames.
- Search engine footprinting to gather publicly available information.
- Network reconnaissance to identify accessible services and hosts.

These techniques allow the application to collect valuable information about the target organization before an attack.

3. How can the information collection process be disabled or modified?

The information collection process can be disabled by modifying or removing the functions responsible for network communication. During reverse engineering, the analyst can patch the executable to bypass reconnaissance functions or replace API calls with harmless instructions. Firewall rules can also block outbound DNS and WHOIS requests. Additionally, disabling unnecessary modules or restricting network access prevents the application from collecting target information.

Task 2: A file named DNSScan.exe has been found during a security audit. Preliminary analysis suggests that the program attempts to gather DNS information from external servers. Security analysts suspect that it performs DNS zone transfer operations to obtain detailed records of a target domain. Reverse engineer the executable to determine its behavior and associated risks.

Questions:

1. Which function is responsible for initiating DNS requests?

The executable DNSScan.exe is expected to use DNS-related functions such as DnsQuery(), gethostbyname(), getaddrinfo(), or other socket-based networking APIs. These functions initiate DNS requests to retrieve information such as IP addresses, mail servers, and DNS records from external DNS servers.

2. Does the application attempt an AXFR (Zone Transfer) request? Justify your answer.

Yes. If reverse engineering reveals that the executable sends DNS queries with the AXFR record type, it indicates that the application attempts a DNS zone transfer. An AXFR request asks a DNS server to provide a complete copy of its DNS database. The presence of AXFR-related API calls, protocol messages, or network traffic confirms this behavior. If the DNS server allows unrestricted zone transfers, the request may successfully retrieve all DNS records.

3. What information can an attacker obtain using the extracted DNS records?

The extracted DNS records may reveal:

- Domain names
- Subdomains
- Internal and external hostnames
- Mail server (MX) records
- Name server (NS) records
- IP addresses
- Server infrastructure details

This information enables attackers to map the organization's network and identify potential targets for future attacks.

Task 3: An organization identifies a tool called IntelGather.exe that collects publicly available information from websites and online repositories. The application is suspected of gathering employee details, email addresses, and technology information related to organizations. Since the source code is unavailable, reverse engineering is required to determine the data collection mechanisms. Analyze the executable and identify its intelligence-gathering capabilities.

Questions:

1. What types of information are collected by the application?

The executable IntelGather.exe is designed to collect publicly available information about an organization. The collected information may include employee names, email addresses, phone numbers, company details, social media profiles, domain names, IP addresses, website technologies, and publicly accessible documents. This information helps build a detailed profile of the target organization.

2. Which external websites or services are accessed during execution?

During execution, the application may access various public services, including:

- WHOIS databases

- Search engines
- Company websites
- LinkedIn
- GitHub
- DNS lookup services
- Technology profiling websites such as BuiltWith
- Public repositories and online databases

These sources provide valuable intelligence without directly interacting with the target network.

3. How can the collected intelligence be misused by attackers?

Attackers can misuse the collected intelligence to perform phishing attacks, social engineering, credential theft, and targeted spear-phishing campaigns. The information can also be used to identify vulnerable systems, discover exposed services, and plan more effective cyberattacks against the organization.

Task 4: A suspicious program named MailCraft.exe is discovered on a compromised system. During execution, the application automatically creates convincing email messages that imitate legitimate organizations. Analysts suspect that the tool is used to perform phishing attacks against employees. Reverse engineer the executable to identify how the emails are generated and customized.

Questions:

1. Which functions are responsible for generating phishing emails?

The executable MailCraft.exe likely contains functions responsible for creating email templates, formatting message content, inserting organization-specific information, and sending emails using SMTP protocols. Reverse engineering can identify these functions by examining string formatting routines, SMTP libraries, and email-related API calls.

2. What information is used to personalize the messages?

The phishing emails are personalized using information such as employee names, company names, job titles, email addresses, department details, company logos, and publicly available

contact information. Personalization increases the likelihood that recipients will trust the email and disclose sensitive information.

3. How can the phishing functionality be prevented or removed?

The phishing functionality can be removed by deleting or patching the email generation and transmission modules within the executable. Organizations should also block SMTP communication, deploy endpoint protection software, implement email filtering, and keep antivirus signatures updated to detect and prevent phishing-related activities.

Task 5: A binary file named PortalClone.exe imitates the login page of a popular online service. Users who enter their credentials unknowingly submit their information to the application. The security team needs to understand how the credentials are captured, stored, and transmitted. Reverse engineer the program to identify its malicious behavior.

Questions:

1. How does the application capture usernames and passwords?

The executable PortalClone.exe captures usernames and passwords by displaying a fake login page that closely resembles a legitimate website. When users enter their credentials, the application intercepts the submitted data before forwarding or storing it. Reverse engineering can identify the functions responsible for processing user input and handling form submissions.

2. Where are the captured credentials stored or transmitted?

The captured credentials may be stored locally in files, databases, or log files within the compromised system. Alternatively, they may be transmitted to a remote attacker through HTTP, HTTPS, SMTP, or other network communication protocols. Reverse engineering helps determine the exact storage location or transmission method.

3. What security risks arise from the use of such applications?

Applications such as PortalClone.exe pose serious security risks, including unauthorized access to user accounts, identity theft, financial fraud, data breaches, credential theft, and compromise of organizational systems. Stolen credentials may also be reused in additional attacks, leading to widespread security incidents.